HYKON INVERTER / UPS IoT MONITORING SYSTEM

Full Project Plan
Backend + Frontend

PRD-1: three roles, device access gate, role-based dashboard

Version: PRD-1 / Plan v2 · Updated: 22 Oct 2026

Repository: sanjaysanthoshdev08/iot-devices-website

DONE completed PART partly done / in progress NOT STARTED <-- YOU ARE HERE

Contents

1. Project information
2. Product requirements (PRD-1): roles, flows, pages
3. Permission matrix
4. What is already COMPLETED - backend
5. What is already COMPLETED - frontend
6. Step 34 tracker (current work)
7. Defects found (to fix)
8. YOU ARE HERE - next 3 actions
9. Full roadmap: Phase A to Phase J (step by step)
10. Data model (database tables)
11. API contract (endpoints)
12. Frontend work list (you do these)
13. UI improvement suggestions
14. Decisions made / open questions
15. Project rules (dev rule, backend-only rule, Git rule, security)
16. Definition of "PROJECT COMPLETE"

1. PROJECT INFORMATION

```
Project root : C:\iot-devices-website
Backend      : C:\iot-devices-website\backend
Frontend     : C:\iot-devices-website (Angular, src\app)
Database     : PostgreSQL 18, database "hykon_iot"
GitHub       : sanjaysanthoshdev08/iot-devices-website (branch main)

Backend stack:
  Java 21, Spring Boot 4.1.1, Maven 3.9.16, Spring Web MVC,
  Spring Data JPA, Spring Security, Jakarta Validation, PostgreSQL,
  JJWT 0.12.6, BCrypt, Actuator, Lombok, DevTools, springdoc-openapi
  3.1.1, JUnit 5, Mockito, Postman, DBeaver, Git/GitHub

Frontend stack:
  Angular 22 (standalone, signals), HttpClient, functional HTTP
  interceptor, localStorage session

Run order for local development:
  1. PostgreSQL running
  2. Backend (set DB_PASSWORD and JWT_SECRET in the terminal first)
     cd C:\iot-devices-website\backend
     .\mvnw.cmd spring-boot:run
  3. Frontend
     cd C:\iot-devices-website
     ng serve      -> http://localhost:4200
  Backend URL: http://localhost:8080
  Swagger:     http://localhost:8080/swagger-ui/index.html
```

2. PRODUCT REQUIREMENTS (PRD-1)

```
Goal:
  Three kinds of users log in to one website. Each passes its own
  access step and then sees one dashboard with four pages:
```

```
  OVERVIEW, SYSTEMS, ACCOUNTS, WARNINGS. What each user can see and
  do depends on the role.

Roles:
  USER               = customer who owns inverter/UPS devices
  DISTRIBUTOR_ADMIN  = admin of one distributor (sells/installs devices)
  HYKON_ADMIN        = HYKON main admin (whole company)
```

FLOW 1 - USER (customer)

```
  Register (name, email, password)  ->  Login (email + password)
  -> click FEATURES page
  -> DEVICE ACCESS page: enter Device ID + Serial Number
  -> success -> DASHBOARD

  Dashboard for USER:
    Overview  : NOT visible
    Systems   : VISIBLE - only the user's own devices, table format
                (table already exists in the UI)
    Accounts  : NOT visible
    Warnings  : VISIBLE - warnings of the user's own devices only

  Extra:
    - User can ADD a 2nd / 3rd / more device (Device ID + Serial).
    - User CANNOT add distributors.
    - User can see which distributor their device is under, plus the
      install location and device details.
    - After the first device, the access page is skipped on later
      logins (decided).
```

FLOW 2 - HYKON ADMIN (main admin)

```
  Login with the HYKON admin email/password (only HYKON has this;
  users and distributors can never get it)
  -> click FEATURES page
  -> NO device access page
  -> DASHBOARD directly

  Dashboard for HYKON ADMIN:
    Overview  : everything - all products/systems sold or shipped
                from the company, which user is under which
                distributor
    Systems   : all devices
    Accounts  : all users, distributors, branches
    Warnings  : all warnings

  Extra:
    - Can add distributors, branches, distributor admins.
    - Can add devices for users. Can add everything.
```

FLOW 3 - DISTRIBUTOR ADMIN

```
  Login with the distributor admin email/password (only for them)
  -> click FEATURES page
  -> DISTRIBUTOR ACCESS page: enter Distributor ID + Branch
  -> success -> DASHBOARD

  Dashboard for DISTRIBUTOR ADMIN:
```

```
    Overview  : only counts for devices/customers under this
                distributor (uses the existing UI cards/texts)
    Systems   : all devices under this distributor
    Accounts  : visible in menu, but clicking shows
                "Not accessible for distributors"
    Warnings  : warnings of customers/devices under this distributor

  Extra:
    - Can add customers and devices for users (inside own
      distributor only).
```

3. PERMISSION MATRIX

Pages	USER	DISTRIBUTOR_ADMIN	HYKON_ADMIN
Overview	hidden	own distributor counts	everything
Systems	own devices	own distributor devices	all devices
Accounts	hidden	"Not accessible" (403)	everything
Warnings	own devices	own distributor	all

Actions	USER	DISTRIBUTOR_ADMIN	HYKON_ADMIN
Self-register	yes	no	no
Login email + password	yes	yes	yes
Access gate	Device ID + Serial	Distributor ID + Branch	skipped
Add own extra device	yes	-	-
See distributor + location	yes (own)	yes	yes
Register device to customer	no	own distributor	any
Create customer accounts	no	own distributor	yes
Create distributors/branches	no	no	yes
Create distributor admins	no	no	yes
Acknowledge warnings	own	own distributor	all

```
Account creation rules:
  - POST /api/v1/auth/register ALWAYS creates a USER.
  - The first HYKON_ADMIN is seeded from environment variables
    (never from a public form).
  - DISTRIBUTOR_ADMIN accounts are created only by HYKON_ADMIN and
    belong to exactly one distributor.
  - Security lives in the backend. Hiding a menu item is NOT
    security; every API checks role + data scope.
```

4. COMPLETED - BACKEND

DONE	Steps 1-7	Java 21, Maven, PostgreSQL 18, Spring Boot 4.1.1, dependencies, project structure, DB connection, Spring Security base
DONE	Steps 8-9	Angular login/signup inspection, package architecture (controller/service/repository/ entity/dto/security/exception/config)
DONE	Steps 10-14	User, Role (USER/ADMIN), RefreshToken entities, User->Role relation, repositories
DONE	Steps 15-18	Register DTO + validation, service, BCrypt, POST /api/v1/auth/register (201)
DONE	Steps 19-22	Login DTO, service, POST /api/v1/auth/login,

		JWT access token (15 min)
DONE	Step 23	Refresh token (SecureRandom, 7 days, PostgreSQL)
DONE	Step 24	Refresh token rotation, POST /api/v1/auth/refresh
DONE	Step 25	Logout + refresh token revocation, POST /api/v1/auth/logout
DONE	Step 26	JWT authentication filter, stateless security, JSON 401 responses
DONE	Step 27	Public vs protected endpoints
DONE	Step 28	URL RBAC: /api/v1/admin/** and /api/v1/user/** (commit c5f69df)
PART	Step 29	Validation for auth DTOs + tests (commit a83eb99). Remaining: validation for every new API.
DONE	Step 30	Global exception handling (@RestControllerAdvice)
DONE	Step 31	Standard ApiResponse success/error format (commit dbd23d8). Later: add timestamp + path.
DONE	Step 32	API versioning /api/v1/
DONE	Step 33	Swagger / OpenAPI docs (commit b338c49)
DONE	Step 34	CORS for http://localhost:4200 (preflight verified)
DONE	Step 36	JUnit 5 - 19 tests, BUILD SUCCESS (22 Oct 2026)
PART	Step 37	Mockito used in LoginServiceTest and SecurityAndValidationTests
PART	Step 38	Test profile with test-only JWT secret (commit 74ec214). DB test strategy in Phase B.
PART	Step 47	Indexes: users.email, refresh_tokens.token, refresh_tokens.user_id
DONE	Step 133	.gitignore verified

Done on 22 Oct 2026:
- PRD-1 written (roles, access gates, 4 dashboard pages).
- A1: JWT_SECRET test issue fixed (application-test.properties + @ActiveProfiles("test")). Main config and DB_PASSWORD untouched. Commit 74ec214, merged to main and pushed. 19 tests pass.
- 34.C evidence script written: backend\scripts\verify-34c-database.ps1 (not committed yet)
- 34.F code review done + browser check of the Sign-up button.

5. COMPLETED - FRONTEND (Angular)

DONE	Public website pages: Home (hero, globe), About, Products, Features, Contact form, footer, navigation
DONE	Login / Signup modal UI with validation and animations
DONE	AuthService: register, login, refresh, logout, session kept in localStorage, currentUser / role signals
DONE	HTTP interceptor: adds "Authorization: Bearer <token>", auto-refresh on 401 with one shared refresh request
DONE	Signup connected to POST /api/v1/auth/register (34.F code)
DONE	Login connected to POST /api/v1/auth/login (34.G)
DONE	Device access page UI (/device-login) - Device ID + Serial
DONE	Dashboard UI with 4 tabs: Overview, Systems, Accounts, Alerts (= Warnings), toasts, system registration modal, account creation modal
DONE	SystemRecordsService and AccountsService (UI side)

Frontend parts that are MOCK / NOT REAL yet (be honest in demos):
- Device access check is FRONTEND-ONLY pattern matching (any "halo1200-1" + "SN-..." passes). Must call the backend (Phase F).
- Systems and Accounts call /api/v1/systems and /api/v1/accounts

which DO NOT EXIST in the backend yet; they fall back to
browser localStorage. Real APIs come in Phases E and G.
- Dashboard readings/numbers are MOCK DATA until ESP32 (Phase I).
- No route guards yet; routes are placeholders (Phase F).
- Whole site is one large component (app.ts ~2270 lines,
app.html ~2680 lines). Splitting into page components is
recommended later (Phase F/G).

6. STEP 34 TRACKER - ANGULAR + SPRING BOOT AUTH INTEGRATION

34.A Backend security verification DONE
34.B Inspect Angular authentication DONE
34.C PostgreSQL evidence IN PROGRESS
Left: re-run verify-34c-database.ps1, report must appear in
backend\docs\evidence\, then commit script + report.
34.D Signup API DONE
34.E Login API DONE
34.F Signup redirect IN PROGRESS
Code reviewed: success -> switches to Login; failures stay on
Signup. Left: fix D1 + D2, then browser test.
34.G Angular Login connected DONE
34.H JWT + protected APIs DONE
34.I Routing + auth state IN PROGRESS
Verified: header "Sign up free" opens Signup (22 Oct).
Left: login redirect, refresh keeps session, logout,
protected routes, Login<->Signup links (D3).
34.J Session + token security IN PROGRESS
Done: JWT_SECRET test config. Left: expiry, refresh, reuse
rejection, logout invalidation, storage review.
34.K End-to-end tests IN PROGRESS
34.L Fix + retest defects NOT STARTED
34.M Teacher demonstration NOT STARTED
34.N Final tests + Git checkpoint NOT STARTED

Demo is READY only when all of these are proven:
- ☐ Signup: Angular -> Spring Boot -> user saved in PostgreSQL
- ☐ Password stored as BCrypt hash, not plaintext
- ☐ Login: valid succeeds, wrong password fails
- ☐ Duplicate email rejected
- ☐ JWT returned on login
- ☐ Protected endpoint: valid token OK, missing/invalid rejected
- ☐ Correct success/error messages and navigation
- ☐ Logout clears state; protected access blocked
- ☐ No unresolved critical errors in the demo flow

7. DEFECTS FOUND (frontend changes are made by YOU)

☐ D1 (34.F) Old auth messages stay visible after closing/reopening
the modal or switching Login<->Signup.
Fix in app.ts clearErrors():
this.authError.set('');
this.authSuccess.set('');

☐ D2 (34.F) Backend down shows "Registration failed. Please try
again." Fix in the signup error handler:

```
        if (error.status === 0) {
          this.authError.set('Cannot reach the server. Please check
          your connection and try again.');
          return;
        }
```

☐ D3 Login-mode link says "Have an account? SignUp".
Should be "Don't have an account? Sign up" (app.html ~line 1367).

☐ D4 Browser tab title is "Global Money Transfer".
Fix in src\index.html <title>: "HYKON IoT Monitoring".

☐ D5 Auth modal image is broken and shows "Login Graphic" text.
app.html line 1271 loads "assets/login.jpg", which does not exist in public\assets. Point it to an existing file (e.g. "assets/Login page background.png") or add login.jpg.

☐ D6 Footer shows "(Company Name)" placeholders. Replace with HYKON.

☐ D7 (security, Phase F) Device access page accepts any well-formed Device ID + Serial. Must verify against the database.

8. YOU ARE HERE - NEXT 3 ACTIONS

```
1. A2 / 34.C  Start backend, then in a 2nd terminal:
     cd C:\iot-devices-website\backend
     $env:DB_PASSWORD="<your-db-password>"
     .\scripts\verify-34c-database.ps1
   Check every line says PASS. Commit script + report.

2. A3 / 34.F  Fix D1 and D2 in Angular. Test in browser:
     - new email -> success message -> Login form
     - same email again -> error, stays on Signup
     - short password -> field error, stays on Signup
     - backend stopped -> "Cannot reach the server", stays on Signup

3. A4 / 34.I  Login redirect, refresh, logout, protected pages.
```

9. FULL ROADMAP - STEP BY STEP

```
Every phase ends with: tests pass -> verify in browser/Postman ->
mark DONE -> git status -> git diff -> commit -> push -> clean tree.
(FE) = Angular work you do yourself.
```

PHASE A - FINISH STEP 34 (signup/login demo)

✓ A1 JWT_SECRET test fix (commit 74ec214)
☐ A2 34.C database evidence **<-- YOU ARE HERE**
☐ A3 34.F (FE) fix D1, D2 + browser test of signup redirect
☐ A4 34.I login redirect, refresh, logout, protected pages, D3
☐ A5 34.J set access token to 1 minute temporarily; check
      silent refresh, old refresh token rejected, logout works;
      set back to 15 minutes
☐ A6 34.K/L full real-UI test (backend down, wrong password,

CORS); fix D4-D6; check Home, About, Product, Features, Dashboard, footer, responsive layout, animations

☐ A7 34.M/N demo script, mvnw clean test, ng build, commit, push, clean tree

Done when: the 9 demo items in section 6 are all proven.

PHASE B - DATABASE READY FOR GROWTH (old 38, 45, 46)

☐ B1 Add Flyway. V1 migration = current roles, users, refresh_tokens. Set spring.jpa.hibernate.ddl-auto=validate.

☐ B2 Test database: Testcontainers PostgreSQL (Docker Desktop is installed) or a separate hykon_iot_test database.

Done when: app starts on a fresh DB using only migrations; tests pass.

PHASE C - THREE ROLES

☐ C1 Migration: rename ADMIN -> HYKON_ADMIN, add DISTRIBUTOR_ADMIN.

☐ C2 Seed first HYKON_ADMIN from HYKON_ADMIN_EMAIL / HYKON_ADMIN_PASSWORD env vars.

☐ C3 GET /api/v1/me -> id, name, role, distributor, accessVerified, visiblePages.

☐ C4 Update SecurityConfig, enable @PreAuthorize, tests for 401/403 per role. Remove temporary RBAC test controller when real endpoints exist.

Done when: one login per role returns the right /me data.

PHASE D - DISTRIBUTORS AND BRANCHES

☐ D-1 Distributor + Branch entities, migration, repositories.

☐ D-2 HYKON_ADMIN APIs: create/list distributors, branches, distributor admins.

☐ D-3 users.distributor_id link; tests.

Done when: HYKON admin creates a distributor, branch and admin login in Postman/Swagger.

PHASE E - DEVICES AND OWNERSHIP (old 61-71)

☐ E1 (FE check) Read Systems table columns in the UI; fix the device field list.

☐ E2 Device entity + migration + repository.

☐ E3 DataScopeService: HYKON = all, DISTRIBUTOR = own distributor, USER = own devices. Used by every query.

☐ E4 Systems APIs: list, detail, create, update.

☐ E5 Ownership tests: User A cannot see User B's device; Distributor X cannot see Distributor Y's devices.

Done when: same URL returns different rows per role; out-of-scope id returns 404.

PHASE F - ACCESS GATE (replaces the frontend-only check, D7)

☐ F1 POST /api/v1/access/device and POST /api/v1/me/devices: Device ID + Serial must match one device; device unowned or already this user's; generic error; rate limit 5 / 15 min.

☐ F2 POST /api/v1/access/distributor: Distributor ID + Branch must match the admin's own distributor.

☐ F3 (FE) Features -> Access page (form by role) -> Dashboard; HYKON_ADMIN skips; USER with a device skips.

☐ F4 (FE) Route guards: authGuard, roleGuard, accessGuard.

Done when: wrong pairs fail, right pairs open the dashboard, and typing the dashboard URL while logged out redirects to login.

PHASE G - DASHBOARD PAGES

☐ G1 Overview API (DISTRIBUTOR_ADMIN, HYKON_ADMIN).

☐ G2 Alert entity + Warnings APIs; seeded sample alerts clearly labelled "Sample data".

☐ G3 Accounts APIs (HYKON_ADMIN) + customer creation (both admins).

☐ G4 (FE) Sidebar built from /me; Accounts shows "Not accessible for distributors" for DISTRIBUTOR_ADMIN.

☐ G5 Demo: one login per role shows the right pages and data.

☐ G6 (FE) Access guard skips the gate for a USER who already owns a device.

☐ G7 Profile: view, update, change password + revoke refresh sessions (old 55-60).

Done when: frontend no longer uses localStorage for systems or accounts; all data comes from the backend.

PHASE H - READINGS AND STATUS (old 72-91)

☐ H1 Confirm reading fields from real inverter / ESP32 data.

☐ H2 Readings table, latest + history APIs with pagination.

☐ H3 Online/offline from last_seen_at; warning thresholds from real inverter specs (not invented values).

PHASE I - ESP32 INGESTION (old 92-101)

☐ I1 Per-device secret (hashed), separate from user JWT.

☐ I2 POST /api/v1/ingest/readings, validation, alert generation.

☐ I3 Dashboard switches from mock to live readings.

Done when: ESP32 values = database values = dashboard values.

PHASE J - PRODUCTION, SECURITY REVIEW, RELEASE (old 35, 39-44, 110-137)

☐ J1 Unit, controller, repository, integration tests for all of the above; full auth flow test.

☐ J2 Profiles (dev/test/prod), secrets out of code, HTTPS, production CORS, safe logging, Actuator health/metrics, error format with timestamp + path.

☐ J3 Dockerfile, PostgreSQL container, Docker Compose, Flyway in production.

☐ J4 Security review, brute-force protection, end-to-end test, remove debug/test code, final commit + push.

10. DATA MODEL

```
roles          id, name  (USER, DISTRIBUTOR_ADMIN, HYKON_ADMIN)
users          id, name, email (unique), password (BCrypt), status,
               role_id, distributor_id (only for distributor
               admins), phone, created_at, updated_at
refresh_tokens id, token, user_id, expires_at, revoked, created_at
distributors   id, code (unique = "Distributor ID"), name,
               contact_email, phone, status, created_at
branches       id, distributor_id, code, name, city, address,
               status   (unique: distributor_id + code)
devices        id, device_uid (unique = "Device ID"),
               serial_number (unique), product_type (INVERTER/UPS),
               model, capacity_va, distributor_id, branch_id,
               owner_user_id (null until claimed), install_address,
               city, latitude, longitude, status, installed_at,
               last_seen_at, created_by
access_verifications  id, user_id, kind (DEVICE/DISTRIBUTOR),
               device_id or branch_id, verified_at
readings       id, device_id, recorded_at, ac_input_v, ac_output_v,
               load_w, battery_v, battery_pct, frequency_hz,
               temperature_c, charging_state   (fields confirmed in
               Phase H)
alerts         id, device_id, type, severity (INFO/WARNING/
               CRITICAL), message, status (ACTIVE/ACKNOWLEDGED/
               RESOLVED), raised_at, acknowledged_by, resolved_at
audit_log      id, actor_user_id, action, target_type, target_id, at

Chain that controls every page:
  Distributor -> Branch -> Device -> Owner (USER)

Scope rule (one service, every query):
  HYKON_ADMIN        -> no filter
  DISTRIBUTOR_ADMIN  -> devices.distributor_id = my distributor
  USER               -> devices.owner_user_id = my id
  Current user always comes from the JWT, never from the request.
  Out-of-scope device -> 404 (not 403), so IDs cannot be guessed.
```

11. API CONTRACT

```
Existing (done):
  POST /api/v1/auth/register    public
  POST /api/v1/auth/login       public
  POST /api/v1/auth/refresh     public
  POST /api/v1/auth/logout      public (refresh token in body)

New:
  GET   /api/v1/me                          all logged in
  POST  /api/v1/access/device               USER
  POST  /api/v1/access/distributor          DISTRIBUTOR_ADMIN
  GET   /api/v1/dashboard/overview          DISTRIBUTOR_ADMIN, HYKON
  GET   /api/v1/systems                     all (scoped)
  GET   /api/v1/systems/{id}                all (scoped)
  POST  /api/v1/systems                     DISTRIBUTOR_ADMIN, HYKON
  PUT   /api/v1/systems/{id}                DISTRIBUTOR_ADMIN, HYKON
  POST  /api/v1/me/devices                  USER
  GET   /api/v1/warnings                    all (scoped)
```

```
PATCH /api/v1/warnings/{id}/acknowledge  all (scoped)
GET   /api/v1/accounts/users             HYKON
POST  /api/v1/accounts/customers         DISTRIBUTOR_ADMIN, HYKON
GET   /api/v1/distributors               HYKON
POST  /api/v1/distributors               HYKON
POST  /api/v1/distributors/{id}/branches HYKON
POST  /api/v1/distributors/{id}/admins   HYKON
GET   /api/v1/profile, PUT /api/v1/profile,
PUT   /api/v1/profile/password           all logged in
POST  /api/v1/ingest/readings            ESP32 (device secret)
```

All responses use ApiResponse<T>. Lists take page, size, search, status. Note: the frontend currently calls /api/v1/accounts and /api/v1/accounts/groups - align names in Phase G (E1 check first).

12. FRONTEND WORK LIST (you do these)

Now (Step 34):

- ☐ D1, D2 signup message fixes
- ☐ D3 link text, D4 tab title, D5 broken image, D6 footer
- ☐ Login redirect + logout behaviour check

Later:

- ☐ Route guards: authGuard, roleGuard, accessGuard (F4)
- ☐ Access page calls backend; form changes by role (F3)
- ☐ Sidebar built from GET /api/v1/me (G4)
- ☐ Systems/Accounts/Warnings use real APIs, remove localStorage fallbacks (G)
- ☐ "Add device" for USER (F1 API)
- ☐ Profile page (G7)
- ☐ Live readings (I3)
- ☐ Split app.ts into page components (home, auth, device-access, dashboard/overview, systems, accounts, warnings)

13. UI IMPROVEMENT SUGGESTIONS

- Header: user name + role badge (Customer / Distributor / HYKON Admin), distributor name, profile menu with Logout.
- Sidebar from /me; Accounts shows a lock icon for distributors.
- Access page: one card, form by role, photo showing where Device ID and Serial are on the inverter label, clear error. Later: QR scan.
- Overview: KPI cards (Total systems, Online, Offline, Active warnings, Customers), status donut, per-distributor bar chart for HYKON admin, last 10 warnings.
- Systems table: search, status filter chips, pagination, sorting, colored status dot, "last seen 3 min ago", row opens a detail drawer with live values + 24 h sparkline; "Add device" for USER.
- Warnings: severity colors, Active / History tabs, Acknowledge.
- Accounts: tabs Users / Distributors / Branches with Add modals.
- States: skeleton loaders, empty states, toasts, session-expired dialog.
- "Sample data" badge on anything not from real hardware.
- Mobile: sidebar becomes bottom nav, tables become cards.

14. DECISIONS / OPEN QUESTIONS

Decided (22 Oct 2026):

- ✓ One device has one customer owner.
- ✓ A USER who already owns a device skips the access page on later logins.

Open:

- ☐ "Distributor admin can add distributors" = sub-distributors / branches, or only customers and devices? (Plan assumes customers and devices only.)
- ☐ Does a distributor admin manage all branches, or only the branch entered at the gate?
- ☐ Who first enters a device: HYKON at the factory (bulk upload of Device ID + Serial) or the distributor at sale?
- ☐ Which exact reading fields does the ESP32 send? (Blocks H.)
- ☐ Customer location: address typed by distributor, or GPS?

15. PROJECT RULES

Backend development rule (every feature that touches Angular):

1. Inspect Angular first 2. Identify fields/models/routes
3. Define API contract 4. Entity 5. Repository 6. Service
7. Controller 8. Security 9. Validation 10. Test API
11. Connect Angular 12. Test full flow

NEVER GUESS FRONTEND REQUIREMENTS.

Backend-only chat rule:

The assistant does not modify Angular code. It explains the change and why; you make the frontend change.

GitHub checkpoint rule (after each milestone):

verify -> run tests -> confirm API -> mark DONE -> git status -> git diff -> git add -> git commit -> git push origin main -> confirm "working tree clean"

Security principles:

- Never store plaintext passwords; use BCrypt; never return hashes
- Never expose JWT secrets or refresh tokens unnecessarily
- Short-lived access tokens; rotate and revoke refresh tokens
- Validate all input; authorize every protected resource
- Enforce device ownership; never trust client-supplied user IDs
- No sensitive info in errors or logs
- HTTPS in production; secrets outside source code; strict CORS
- Database constraints + migrations; test auth and authorization

16. DEFINITION OF "PROJECT COMPLETE"

- ☐ All three roles log in and see exactly their pages and data
- ☐ Access gates verified by the backend (no frontend-only checks)
- ☐ User A can never see User B's device; Distributor X never sees Distributor Y's devices
- ☐ Systems, Accounts, Warnings, Overview served by real APIs
- ☐ ESP32 -> backend -> PostgreSQL -> dashboard shows real values

- ☐ Flyway migrations build the whole schema
- ☐ All backend tests pass; ng build succeeds
- ☐ Security review done; secrets in env vars; HTTPS in production
- ☐ Docker Compose runs backend + PostgreSQL
- ☐ Final commit pushed; working tree clean